

Glossary of Technical Terms

Nidhi Sharma

VBoxClient

A background service installed with VirtualBox Guest Additions that enables features like drag-and-drop, shared clipboard, and auto screen resizing between host and guest VM.

DNS (Domain Name System)

The system that translates human-readable domain names (e.g., google.com) into IP addresses computers use to communicate.

DHCP

Dynamic Host Configuration Protocol automatically assigns IP addresses and network configuration to devices in a network.

Proxy (HTTP Proxy)

An intermediary between a client and server that can intercept, inspect, or modify network traffic, often used in testing tools like Burp Suite or ZAP.

OWASP ZAP (Zed Attack Proxy)

An open-source web application security scanner used for automated vulnerability detection and manual testing.

Burp Suite

A popular web security testing tool with manual proxy, scanner, and various other testing capabilities.

Spider (Crawling)

An automated process in security scanners that follows links in a web app to enumerate available pages and functionality.

XSS (Cross-Site Scripting)

A web security flaw allowing attackers to execute malicious scripts in users' browsers by injecting code into web pages.

HTML/JS Escaping

Security practice converting special characters in HTML or JavaScript to safe representations to prevent code injection attacks like XSS.

Allow-listing (Whitelisting)

A security measure that permits only pre-approved entities (applications, IPs, users) access or execution rights, blocking everything else by default.

Directory Listing

When a web server shows the list of files and folders inside a directory if no default index file is present, which can leak sensitive information.

CSRF (Cross-Site Request Forgery)

An attack where unauthorized commands are transmitted from a user trusted by the web application.

Rate-Limiting

Restricting the number of requests a user can make to a service in a given period to prevent brute-force or DoS attacks.

CAPTCHA

A challenge-response test to determine if the user is human, often used to deter automated attacks.

HSTS (HTTP Strict Transport Security)

A security policy forcing browsers to interact with a website only over HTTPS, protecting against downgrade attacks.

EXIF Metadata

Information embedded in image files (like camera settings, location) that can sometimes be used to hide data.

Stenography

The practice of hiding data within files (images, audio) to conceal information.

Session Token/Cookie

Data used by web servers to identify and maintain stateful sessions with authenticated users.

Reflected XSS

XSS vulnerability where malicious script is reflected off a web server, typically via a URL parameter.

Blind SQL Injection

A type of SQL injection where data is inferred by changes in response rather than direct error messages.

Redirect Validation

Ensuring that URL redirects only go to trusted locations to prevent phishing or open redirect vulnerabilities.

Active Scan

Automated vulnerability scan mode in security tools (e.g., OWASP ZAP) that actively probes a web app for security flaws by sending crafted requests.

CSP (Content Security Policy)

A security header that restricts sources of content on a webpage to prevent Cross-Site Scripting and data injection attacks.

Directory Enumeration

The process of systematically discovering hidden or non-linked directories/files on a web server using tools like Dirb.

Dirb

A command-line web content scanner that uses wordlists to find hidden directories and files on web servers.

Flag

A secret string or token placed in a system as part of a Capture-The-Flag challenge, used to prove successful exploitation or discovery.

Input Validation

Checking and sanitizing user inputs to ensure they conform to expected formats, preventing injection and manipulation attacks.

phpinfo()

A PHP function displaying configuration and environment information. Should be removed or restricted in production environments.

Robots.txt

A file used by websites to inform web crawlers which paths or pages should not be crawled or indexed.

Security Headers

HTTP headers (like CSP, X-Frame-Options) that instruct browsers to guard against attacks such as clickjacking, XSS, and more.

Session Management

Mechanisms that control user authentication sessions, including creation, maintenance, expiration, and protection from hijacking.

Vulnerability

A weakness or flaw in software or configuration that can be exploited to compromise confidentiality, integrity, or availability.

Web Application Firewall (WAF)

A firewall that filters, monitors, and blocks HTTP traffic to/from a web app based on predefined security rules.